

SECURITY ADVISORY

ChatGPT Stealer “Prompt Poaching”

Advisory ID	
Date Issued	
Severity	
Affected Scope	Any user with Chrome/Edge browser and AI chatbot extensions installed
Threat Category	Browser Extension Abuse / Data Exfiltration / Prompt Poaching

Executive Summary

Cybersecurity researchers at OX Security and Secure Annex have identified at least two malicious Chrome extensions with a combined install base of over 900,000 users that are silently exfiltrating ChatGPT and DeepSeek conversation data to attacker-controlled servers. The technique, codenamed Prompt Poaching, represents an emerging and highly scalable method of harvesting sensitive AI chatbot interactions through weaponized browser add-ons.

This threat is particularly significant for organizations whose employees use AI tools for work-related tasks, as full conversation histories may contain intellectual property, internal project details, customer data, and confidential business strategies. The malicious extensions are still available for download on the Chrome Web Store and actively masquerade as legitimate AI productivity tools. All clients should assume that any employee who has installed AI-related Chrome extensions may be affected and should take immediate action as outlined in this advisory.

Threat Overview

Identified Malicious Extensions

The two confirmed malicious extensions identified are:

- Chat GPT for Chrome with GPT-5, Claude Sonnet & DeepSeek AI.
Extension ID: fnmihdojmnkclgjpcoonokmkhjpechg
- AI Sidebar with Deepseek, ChatGPT, Claude, and more
Extension ID: inhcgfpbfdbjogdfjbclgolkmhnooop

Both extensions impersonate a legitimate tool named "Chat with all AI models (Gemini, Claude, DeepSeek...) & AI Agents" published by AITOPIA, which has approximately one million genuine users. The "Chat GPT for Chrome with GPT-5" extension has since had its Chrome Web Store "Featured" badge revoked, however it remained available for installation at time of writing.

How the Attack Works

Upon installation, the extensions request permission to collect what they describe as "anonymous, non-identifiable analytics data" to improve the user experience. Once this consent is granted, the malware activates its exfiltration routine. The extensions scrape DOM elements inside ChatGPT and DeepSeek web sessions to extract full conversation content, then bundle this data alongside all open browser tab URLs and transmit the package to a remote command-and-control (C2) server at

30-minute intervals. Identified C2 infrastructure includes the domains chatsaigpt[.]com and deepaichats[.]com. Additionally, the threat actors used Lovable, an AI-powered web development platform, to host their phishing-style privacy pages and supporting infrastructure at chataigpt[.]pro and chatgptsidebar[.]pro, further obscuring the malicious operation.

Impact & Risk

Organizations whose employees have these extensions installed may have unknowingly exposed: full AI chatbot conversation histories including internal project discussions, intellectual property and trade secrets shared with AI assistants, internal corporate URLs visible in browser tab metadata, and sensitive data such as personally identifiable information (PII) or customer records entered into AI tools. This data can be weaponized for corporate espionage, targeted spear-phishing, identity theft, or sold on criminal marketplaces.

Indicators of Compromise (IOCs)

Type	Indicator
Extension ID	fnmihdojmnkclgjpcoonokmkhjppjechg
Extension ID	inhcgfpbfdbjbjogdfjbclgolkmhnooop
C2 Domain	chatsaigpt[.]com
C2 Domain	deepaichats[.]com
Infra Domain	chataigpt[.]pro
Infra Domain	chatgptsidebar[.]pro

Recommendations

- Audit installed Chrome and Edge extensions across all managed endpoints. Use your endpoint management platform or browser policy tooling to enumerate installed extensions. Immediately flag and remove the two identified malicious extension IDs listed in the IOC table above.
- Block the identified C2 and infrastructure domains. Add chatsaigpt[.]com, deepaichats[.]com, chataigpt[.]pro, and chatgptsidebar[.]pro to your blocklist and perimeter firewall deny list.
- Alert affected users and request self-remediation. Notify any employees found to have the extensions installed. Instruct them to remove the extension immediately and clear browser cookies and session data as a precaution. Consider requiring a password reset for any accounts accessed during the exposure window.